

Universidad Siglo 21

Seminario de Práctica

Seguimiento de vulnerabilidades por proyecto

Trabajo práctico 1: definición y análisis del proyecto

Daniel Sebastián Rodríguez

Legajo: VINF016869

Licenciatura en Informática

Modalidad EDH

7 de septiembre de 2026

1. Título, introducción y justificación

Título del proyecto: Sistema de seguimiento de vulnerabilidades por proyecto.

Propongo desarrollar una aplicación de escritorio para registrar vulnerabilidades, calcular su severidad con CVSS y seguir su corrección. Los hallazgos se organizarán por proyecto y activo. El administrador podrá gestionar los registros y las cuentas; cada cliente podrá consultar las vulnerabilidades de los proyectos que tenga asignados.

Tomo como contexto de aplicación el área tecnológica de Derechos Del Fútbol, donde realizo tareas de administración de sistemas, bases de datos y herramientas internas. El proyecto se relaciona con el mantenimiento de esos recursos y con la consulta de los hallazgos que requieran atención. El área tecnológica administrará la información; las personas autorizadas a consultar un proyecto tendrán una cuenta con rol cliente.

Elegí este tema por su relación con mi actividad y porque permite aplicar los contenidos de la materia en una aplicación que reúne registro de datos, cálculo, permisos de acceso y seguimiento de tareas.

1.1 Problema y justificación

El seguimiento de una vulnerabilidad requiere relacionar el hallazgo con el recurso afectado, conocer su severidad, definir quién se encargará de corregirlo y registrar el resultado. Cuando se trabaja con varios proyectos, también hace falta separar la información que puede consultar cada usuario.

La aplicación propuesta reunirá esos datos en un registro por hallazgo. El administrador podrá consultar los pendientes por proyecto, estado y severidad. El cliente tendrá acceso al detalle y al historial de sus proyectos, de modo que pueda conocer el avance sin modificar las decisiones de tratamiento.

La calculadora CVSS permitirá obtener una puntuación a partir de las características que ingrese el administrador. El sistema guardará los valores utilizados y el resultado para poder revisar esa evaluación. El historial, por su parte, conservará los cambios de estado y el comentario que los explica.

En la lectura 1, «Sistemas de información», se estudian las entradas, los procesos y las salidas de un sistema. En este proyecto, las entradas serán los proyectos, activos y hallazgos; los procesos comprenderán su registro, evaluación y seguimiento; las salidas serán las consultas y los listados (Universidad Siglo 21, s. f.).

2. Definiciones del proyecto y del sistema

2.1 Objetivos del proyecto

Objetivo general: desarrollar una aplicación de escritorio en Java y MySQL para gestionar el seguimiento de vulnerabilidades por proyecto, aplicando el Proceso Unificado de Desarrollo (PUD).

Los objetivos específicos son definir los requisitos y casos de uso; diseñar el modelo de clases y la base de datos; implementar el registro, la evaluación CVSS y los permisos de acceso; y probar el seguimiento de un hallazgo desde su alta hasta su cierre o reapertura.

2.2 Objetivos del sistema

El sistema deberá permitir al administrador registrar hallazgos sobre activos, calcular su severidad, asignar responsables y fechas, y documentar los cambios de estado. Cada cliente deberá poder consultar el detalle y el historial de las vulnerabilidades de sus proyectos. La información se guardará en MySQL.

2.3 Alcance

Se incluyen proyectos, activos, responsables de corrección, vulnerabilidades, seguimientos y usuarios. Habrá dos roles: administrador y cliente. El administrador gestionará las cuentas y asignará un cliente a cada proyecto. Un cliente podrá tener varios proyectos.

La evaluación utilizará la puntuación base de CVSS 3.1. El administrador seleccionará sus ocho métricas y el sistema calculará el resultado. Un hallazgo podrá registrarse antes de ser evaluado; en ese caso figurará como «Sin evaluar».

La aplicación se desarrollará con Java, Swing y MySQL para una demostración de escritorio en un equipo de prueba. La identificación de vulnerabilidades y su corrección se realizarán sobre los activos, fuera de la aplicación. El sistema registrará esas tareas y su resultado. No se incluyen un escáner, explotación de vulnerabilidades ni remediación automática.

2.4 Aplicación del PUD

Aplicaré el PUD mediante iteraciones guiadas por los casos de uso. En el inicio se definirán el problema y el alcance. En la elaboración se trabajará sobre los requisitos y la arquitectura. La construcción comprenderá la programación y las pruebas; la transición, la preparación de la demostración y la revisión con el usuario de referencia.

Entrega	Trabajo previsto
TP1	Análisis del problema, objetivos, alcance, requisitos, modelo de dominio y casos de uso.
TP2	Diseño de clases e interacciones; modelo relacional y scripts MySQL.
TP3	Implementación en Java de la lógica, las colecciones, el cálculo y los controles de acceso, con una interfaz de consola.
TP4	Interfaz Swing, integración con MySQL mediante JDBC y pruebas del funcionamiento completo.

3. Elicitación y definición de requisitos

El relevamiento inicial se apoya en la revisión documental y en mi actividad en el área tecnológica. A partir de ese contexto definí una propuesta de seguimiento por proyecto, con acceso de administración y consulta. La lectura 1 aporta los conceptos de sistemas de información y las técnicas de elicitación utilizadas para organizar el análisis.

Fuente	Aporte al proyecto
Actividad en Derechos Del Fútbol	Administración de sistemas, bases de datos y herramientas internas. Define el área de aplicación.
Lectura 1: Sistemas de información	Identificación de entradas, procesos, salidas y participantes.
Consigna y rúbrica del TP1	Objetivos, análisis del negocio, requisitos y casos de uso que se deben desarrollar.
Aclaración docente del 31/8/2026	Diagrama general y descripción breve de todos los casos de uso; detalle de dos o tres críticos.
Especificación CVSS 3.1 de FIRST	Métricas, puntuación base, vector y categorías de severidad que utilizará la calculadora.

3.1 Reglas propuestas

Cada activo pertenecerá a un proyecto y cada vulnerabilidad estará asociada a un activo. El proyecto tendrá un cliente asignado. La cuenta autenticada determinará qué proyectos puede consultar el usuario.

Un hallazgo se registrará en estado PENDIENTE y podrá quedar sin responsable y sin evaluación CVSS. Para iniciar su tratamiento deberá tener responsable y fecha objetivo. El cierre requerirá un comentario con la verificación realizada. Si el hallazgo vuelve a necesitar atención, el administrador podrá reabrirlo e indicar el motivo.

Para completar el relevamiento queda por describir cómo se registran actualmente los hallazgos, quiénes intervienen y qué información necesitan consultar las personas a cargo de cada proyecto.

3.2 Validación prevista

Se revisará un caso de seguimiento con el usuario de referencia: registro del hallazgo, evaluación, asignación, tratamiento y cierre. También se comprobará qué datos necesita ver el cliente y si la separación por proyecto resulta adecuada. Los cambios acordados se incorporarán a los requisitos y al diseño.

4. Conocimiento del negocio y modelo de dominio

Derechos Del Fútbol desarrolla su actividad en el ámbito jurídico deportivo. El proyecto se ubica en el área tecnológica que administra sus sistemas, bases de datos y herramientas internas. El proceso que se propone informatizar es el seguimiento de hallazgos de seguridad sobre esos recursos.

El administrador organizará los activos por proyecto, registrará los hallazgos y coordinará su seguimiento. El responsable de corrección realizará el trabajo sobre el activo. El cliente consultará la información de los proyectos que le hayan sido asignados.

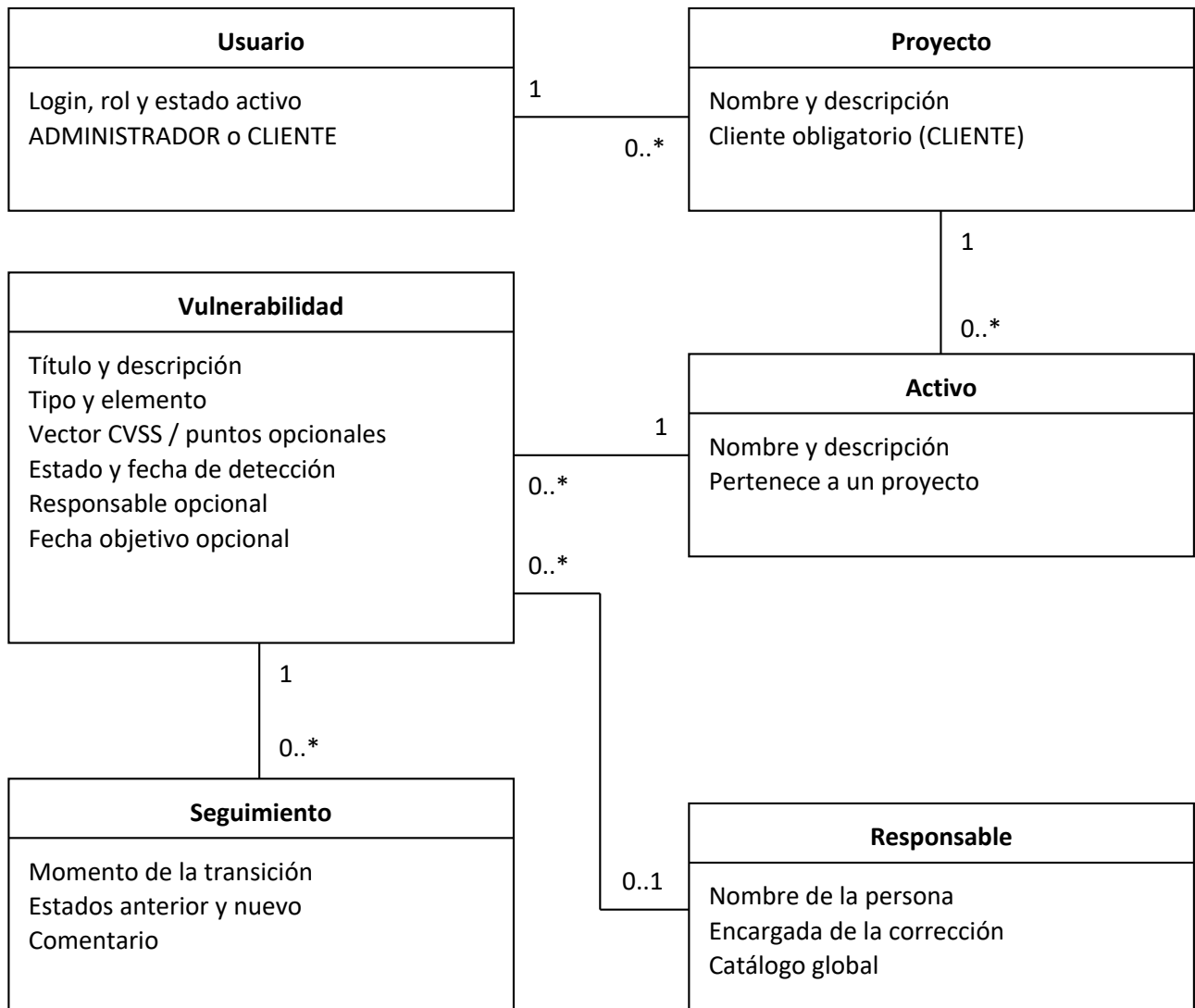


Figura 1. Modelo de dominio. Elaboración propia.

El modelo tiene seis entidades. Un Usuario con rol cliente puede consultar varios Proyectos, y cada proyecto tiene un cliente asignado. Un Activo pertenece a un proyecto y puede tener varias Vulnerabilidades. Cada vulnerabilidad puede tener un Responsable y varios Seguidimientos. El responsable identifica a quien realiza la corrección; la cuenta de usuario determina el acceso a la aplicación.

El proyecto de una vulnerabilidad se obtiene a través de su activo. Una vez que un activo tenga hallazgos, no se permitirá trasladarlo a otro proyecto, para evitar que cambie el acceso a su información.

5. Requisitos funcionales

Cada requisito se relaciona con un caso de uso del mismo número. Las descripciones de las tablas indican la función y el resultado esperado.

RF / CU	Descripción breve
RF01 / CU01 Gestionar activos	El administrador da de alta, modifica y lista activos dentro de un proyecto. Solo puede borrar o trasladar un activo si no tiene vulnerabilidades asociadas.
RF02 / CU02 Gestionar responsables	El administrador da de alta, modifica y lista responsables de corrección. Solo puede borrar uno si no tiene vulnerabilidades asignadas.
RF03 / CU03 Registrar vulnerabilidad	El administrador registra título, descripción, tipo, elemento afectado, activo y fecha de detección. El sistema asigna un ID y estado PENDIENTE. La asignación y la evaluación CVSS pueden completarse después.
RF04 / CU04 Asignar responsable	El administrador asigna un responsable existente y una fecha objetivo igual o posterior a la detección. Puede modificar la asignación mientras la vulnerabilidad no esté en estado CERRADA.
RF05 / CU05 Consultar vulnerabilidades	El administrador consulta todos los proyectos. El cliente consulta solo los suyos. Ambos pueden abrir el detalle y combinar filtros de proyecto, estado y severidad, incluida la opción «Sin evaluar».
RF06 / CU06 Cambiar estado	El administrador inicia tratamiento, cierra o reabre un hallazgo. El sistema valida la transición, exige comentario y guarda el estado y el seguimiento en una misma operación.
RF07 / CU07 Consultar historial	El usuario consulta fecha y hora, estado anterior, estado nuevo y comentario de cada transición. Se aplican los mismos permisos por proyecto que en CU05.
RF08 / CU08 Exportar listado	El administrador guarda el resultado de la consulta filtrada en un archivo TXT UTF-8 nuevo. El sistema informa si el archivo se guardó o si ocurrió un error.

Las vulnerabilidades se conservarán para consultar su historial. Cuando se resuelvan pasarán a CERRADA. El historial registrará las transiciones de estado; la reasignación y la modificación del cálculo CVSS actualizarán los datos del hallazgo sin crear una transición.

5.1 Proyectos, usuarios y evaluación CVSS

RF / CU	Descripción breve
RF09 / CU09 Gestionar proyectos	El administrador crea y modifica proyectos, y les asigna una cuenta activa con rol cliente. Solo puede borrar un proyecto sin activos. Al cambiar el cliente asignado, el acceso pasa a la nueva cuenta.
RF10 / CU10 Gestionar usuarios	El administrador crea cuentas con nombre de acceso único, contraseña y rol ADMINISTRADOR o CLIENTE; puede cambiar contraseñas y desactivar cuentas. El rol queda fijo al crear la cuenta. No se permite desactivar al último administrador activo.
RF11 / CU11 Iniciar y cerrar sesión	El sistema valida las credenciales de una cuenta activa y habilita las operaciones de su rol. Al cerrar sesión, elimina la sesión y los datos visibles de la cuenta anterior.
RF12 / CU12 Calcular CVSS	El administrador selecciona las ocho métricas base de CVSS 3.1. El sistema calcula la puntuación y la categoría, y guarda versión, vector y resultado en el hallazgo. Permite recalcular con otras métricas.

5.2 Permisos

El administrador utiliza todos los casos de uso. El cliente utiliza CU05, CU07 y CU11: inicia sesión, consulta sus vulnerabilidades e historial y cierra sesión. La comprobación de permisos se realizará en la lógica de cada operación y en las consultas por proyecto.

Durante la preparación inicial del prototipo se creará la primera cuenta de administrador con una contraseña elegida para la instalación. A partir de esa cuenta se darán de alta los demás usuarios mediante CU10.

5.3 Cálculo de severidad

Se utilizará CVSS 3.1 Base porque permite realizar el cálculo a partir de ocho métricas: vector de ataque (AV), complejidad del ataque (AC), privilegios requeridos (PR), interacción del usuario (UI), alcance (S) e impactos sobre confidencialidad, integridad y disponibilidad (C, I y A).

El resultado se guardará con un decimal, junto con el vector que contiene los valores seleccionados. Las categorías serán ninguna (0,0), baja (0,1-3,9), media (4,0-6,9), alta (7,0-8,9) y crítica (9,0-10,0). «Sin evaluar» indicará que todavía no se completó el cálculo. CVSS expresa severidad técnica; la prioridad de atención también dependerá del proyecto y del criterio del administrador (FIRST, 2019).

6. Requisitos no funcionales y solución propuesta

ID	Requisito y comprobación prevista
RNF01 Plataforma	Aplicación de escritorio desarrollada en Java y Swing, con persistencia MySQL mediante JDBC. Compilar y ejecutar con las instrucciones del proyecto.
RNF02 Integridad	Rechazar campos obligatorios vacíos, referencias inexistentes, fechas objetivo anteriores a la detección y transiciones inválidas, conservando los datos anteriores.
RNF03 Persistencia	Guardar los registros en MySQL. Comprobar su recuperación al volver a iniciar la aplicación. El cambio de estado y su historial deben confirmarse juntos o revertirse si falla una escritura.
RNF04 Acceso	Exigir una sesión activa y comprobar el rol y el proyecto en cada operación de gestión o consulta. Probar que un cliente no pueda consultar un hallazgo ajeno aunque indique su ID.
RNF05 Contraseñas	Almacenar contraseñas mediante un algoritmo de hash para contraseñas con sal individual. Comprobar que no se guarden ni se muestren en texto plano.
RNF06 Cálculo	Validar las ocho métricas y el redondeo de CVSS 3.1. Comparar los resultados con la calculadora oficial de FIRST, incluidos valores de los límites de cada categoría.
RNF07 Interfaz	Mostrar etiquetas y mensajes en español, fechas con formato explícito y acciones acordes al rol. Informar los errores de entrada, conexión y escritura.
RNF08 Archivos	Exportar exactamente las filas consultadas, en UTF-8 y sin sobrescribir archivos existentes. Comprobar tildes, eñes y cantidad de registros.

La interfaz Swing permitirá iniciar sesión y utilizar los formularios y listados correspondientes a cada rol. El controlador coordinará las operaciones, el modelo aplicará las reglas y las clases de acceso a datos consultarán MySQL. El prototipo se demostrará en un equipo controlado, con cuentas y proyectos de prueba.

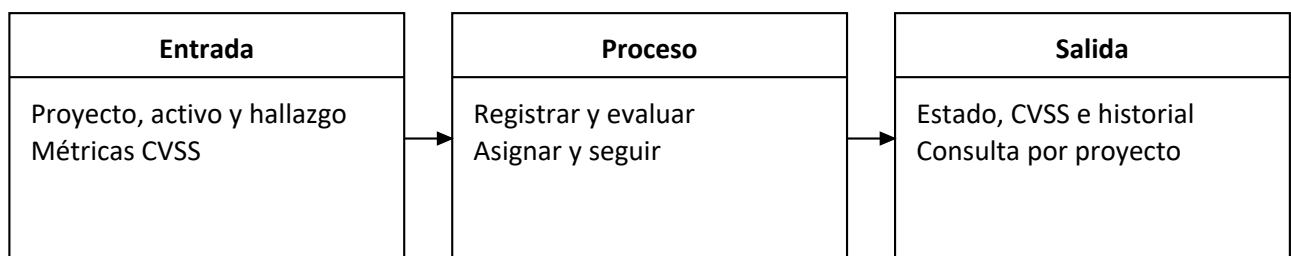


Figura 2. Entradas, procesos y salidas del sistema. Elaboración propia.

7. Casos de uso

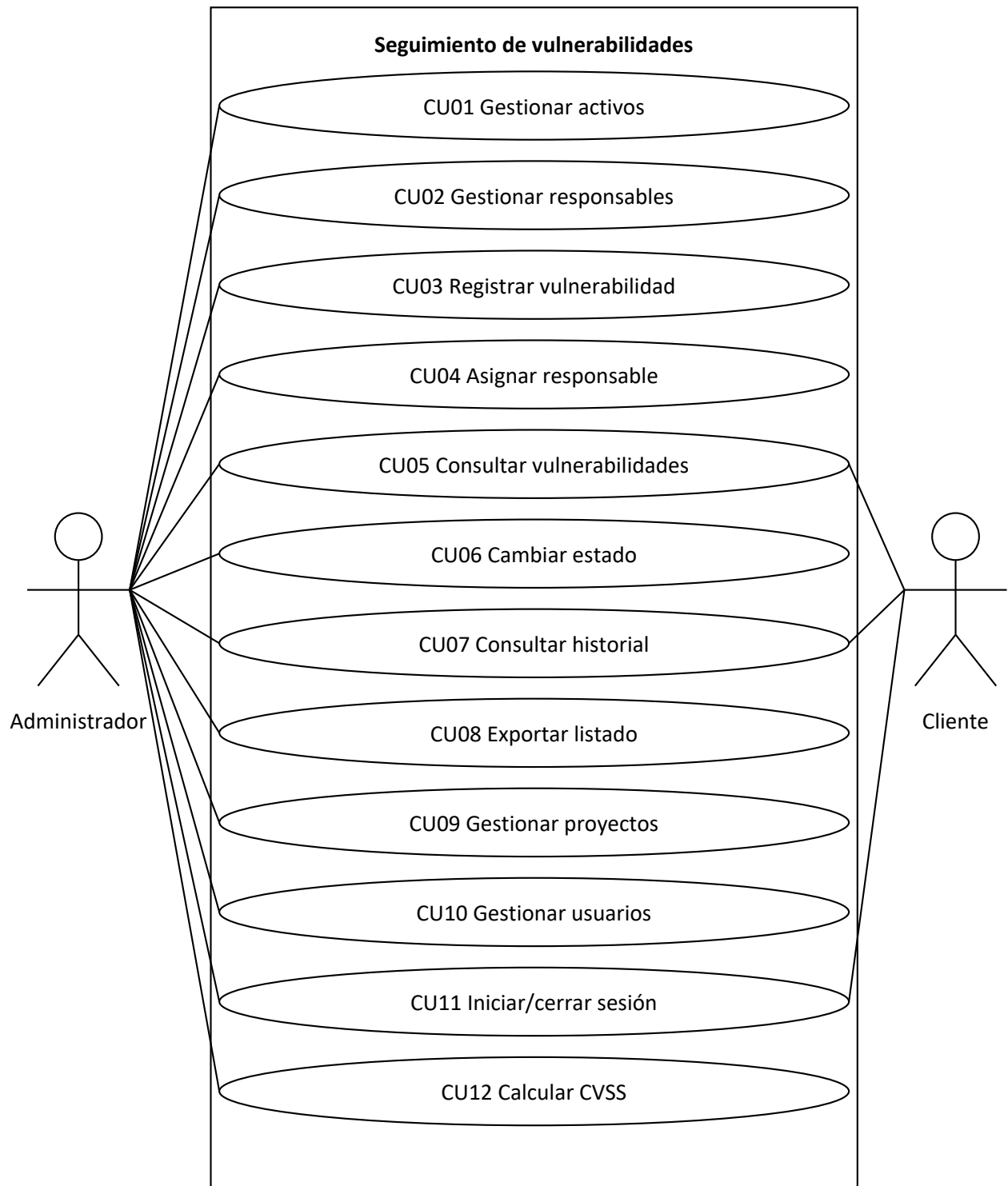


Figura 3. Diagrama general de casos de uso. Elaboración propia.

El administrador gestiona la información y las cuentas. El cliente consulta las vulnerabilidades y el historial de sus proyectos. Las tablas de las secciones 5 y 5.1 describen los doce casos.

Se detallan CU03, CU06 y CU11 para describir el registro, el seguimiento y el acceso al sistema, siguiendo la indicación de desarrollar dos o tres casos críticos (Ojeda, 2026).

7.1 CU03: Registrar vulnerabilidad

Actor: administrador. **Objetivo:** incorporar un hallazgo asociado a un activo. **Requisito:** RF03.

Precondiciones: sesión de administrador activa; proyecto y activo existentes. Se dispone del título, la descripción, el tipo, el elemento afectado y la fecha de detección.

Flujo principal: 1) el administrador selecciona el proyecto y el activo; 2) completa los datos del hallazgo; 3) el sistema comprueba los campos y las referencias; 4) crea el registro con ID único y estado PENDIENTE; 5) confirma el alta y muestra el detalle.

Alternativas: si falta un dato obligatorio o la fecha tiene un formato inválido, se indica qué debe corregirse. Si el activo no existe o no pertenece al proyecto seleccionado, se rechaza el alta. Si falla el almacenamiento, se informa el error. Una cuenta cliente no puede ejecutar esta operación.

Resultado: el hallazgo queda disponible para consulta, todavía sin responsable, fecha objetivo ni evaluación CVSS. El historial comienza vacío. Después del alta pueden ejecutarse CU04 y CU12 para completar la asignación y el cálculo.

Comprobación prevista: registrar un hallazgo válido; repetir con un activo de otro proyecto y comprobar el rechazo sin crear un registro.

7.2 CU11: Iniciar y cerrar sesión

Actores: administrador y cliente. **Objetivo:** acceder con los permisos de la cuenta. **Requisito:** RF11.

Precondición para iniciar: cuenta existente y activa.

Flujo principal: 1) el usuario ingresa nombre de acceso y contraseña; 2) el sistema verifica las credenciales; 3) establece la sesión con ID y rol; 4) presenta las operaciones autorizadas; 5) al elegir cerrar sesión, limpia la sesión, los listados y la selección anterior, y vuelve a la pantalla de acceso.

Alternativas: si las credenciales son incorrectas o la cuenta está inactiva, se muestra un mensaje de acceso rechazado. Una falla de conexión impide abrir la sesión. Si una cuenta es desactivada durante una sesión, la siguiente operación se rechaza y se vuelve al acceso.

Resultado: el administrador puede gestionar; el cliente solo puede consultar sus proyectos. Antes de iniciar sesión y después de cerrarla, las operaciones sobre datos quedan bloqueadas.

Comprobación prevista: iniciar con un cliente y consultar un proyecto propio; intentar abrir el ID de un hallazgo ajeno; cerrar sesión y verificar que se vacíen los datos visibles.

7.3 CU06: Cambiar estado y registrar seguimiento

Actor: administrador. **Objetivo:** actualizar el estado de un hallazgo y registrar el motivo. **Requisito:** RF06, relacionado con RF04 y RF07.

Precondiciones: sesión de administrador activa y vulnerabilidad existente. Para iniciar tratamiento debe tener responsable y fecha objetivo.

Flujo principal: 1) el administrador selecciona el hallazgo; 2) el sistema muestra su estado; 3) el administrador elige la transición y escribe un comentario; 4) el sistema valida los datos; 5) guarda el nuevo estado y un seguimiento con fecha y hora, estado anterior, estado nuevo y comentario; 6) confirma el cambio y actualiza la consulta.

Alternativas: se rechazan el cambio al mismo estado, el cierre directo desde PENDIENTE, el inicio sin asignación y el comentario vacío. Para cerrar, el comentario debe describir la verificación realizada. Para reabrir, debe indicar el motivo. Si falla una escritura, se revierte la operación y se conserva el estado anterior. Una cuenta cliente no puede cambiar estados.

Resultado: el estado actual coincide con el último seguimiento. La reapertura conserva el responsable y la fecha objetivo existentes. El administrador puede ajustar esa asignación mediante CU04.

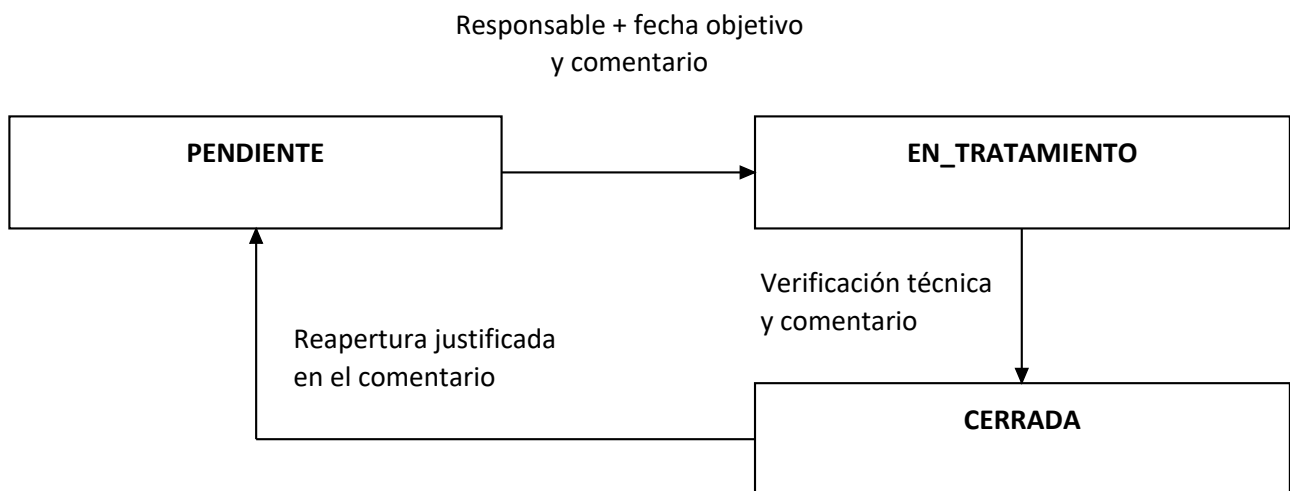


Figura 4. Estados y transiciones admitidas. Elaboración propia.

Comprobación prevista: asignar, iniciar tratamiento, cerrar y reabrir un hallazgo. Verificar tres seguimientos y estado final PENDIENTE. Intentar un cierre directo y confirmar que no cambien el estado ni el historial.

8. Trazabilidad y referencias

Necesidad	RF / CU	Comprobación prevista
Organizar los recursos	01, 02, 09	Crear proyectos y catálogos; rechazar borrados con referencias y el traslado de un activo con hallazgos.
Registrar y evaluar	03, 12	Registrar un hallazgo sin evaluar; calcular CVSS; guardar vector y resultado; rechazar métricas incompletas.
Asignar la corrección	04	Aceptar una asignación válida y rechazar una fecha anterior a la detección.
Consultar por proyecto	05, 07	Combinar filtros y consultar historial; impedir que un cliente acceda a un hallazgo ajeno.
Conservar el seguimiento	06, 07	Completar el ciclo de estados y comprobar que una falla no deje un cambio sin historial.
Administrar el acceso	10, 11	Crear cuentas, iniciar y cerrar sesión; rechazar credenciales incorrectas y cuentas inactivas.
Obtener un listado	08	Exportar las filas filtradas y comprobar el archivo UTF-8.

Referencias

FIRST. (2019). Common Vulnerability Scoring System v3.1: Specification Document. <https://www.first.org/cvss/v3.1/specification-document>

FIRST. (s. f.). CVSS v3.1 Calculator. <https://www.first.org/cvss/calculator/3.1>

Ojeda, docente adscripto. (2026, 31 de agosto). Aclaración sobre casos de uso en el foro de seguimiento [Foro de Canvas]. Universidad Siglo 21. https://siglo21.instructure.com/courses/46312/discussion_topics/550683

Universidad Siglo 21. (s. f.). Lectura 1: Sistemas de información [Material de Seminario de Práctica]. Canvas, curso 46312.

Universidad Siglo 21. (2026). Trabajo práctico 1: consigna, enunciado y rúbrica. <https://siglo21.instructure.com/courses/46312/assignments/510125>

Repositorio del proyecto: Seguimiento de vulnerabilidades en GitHub.